ملخص اختبار الاختراق
/ريان الرشود

رفع الصلاحيات

- لاخذ جلسة
  - windows — hta payload
  - Linux — nc — ssh
- Web/API — PATCH
- Windows
  - winpeas
  - Powerup.ps1
  - Potato family
  - بالهاش
    - Mimikatz — اخذ الهاش من الذاكرة
    - Rubeus — PTK, PTH
    - Crack hash — Hashcat
    - اذا كان يبدأب $ غالبا عشوائي ويستحيل كسره
- Linux
  - Linpeas
  - Groups abuse
  - Sudo
- Metasploit (both) — local_exploit_suggester

الفحص

- تصفح الموقع HTTP
  - كشف الملفات
    - Crawl
      - Paracrawler — ممتازة لرصد نسخ ارقام التقنيات
      - Katana
    - Force browsing
      - Directory brute force — Ffuf -u target.com/FUZZ -w /usr/share/wordlists/dirb/common.txt — اذا ظهرت جميع الصفحات في النتيجة اذا يجب تفعيل امر الفلترة التلقائية — ffuf -ac
      - vHost Fuzzing — Ffuf -u target.com/ -H 'Host: FUZZ.target.com' -w /usr/share/wordlists/dirb/common.txt
    - ناظر كل الطلبات اللي مرت في Burp ممكن تلقى API
    - Google dork — site: target.com admin
    - /robots.txt — قد تظهر اسماء ملفات مهمة
  - كشف التقنيات
    - Web Technology
      - wappalyzer browser extension
      - whatweb
    - View page source — ايضا ابحث عن hardcoded credentials
    - Browser tab title
    - Error pages — لا وجود لصفحة معدلة قد يساعد في جمع معلومات كثيرة
    - Nmap -sV
    - كشف امتداد الموقع web extension
      - Fuzzing — ffuf -e .php
      - Crawling — قد يظهر احد صفحات الامتداد
      - Wappalyzer
- فحص البورتات
  - Nmap
    - اساسي — Nmap 10.xxx - sCV --reason
    - --reason
      - لاظهار TTL
        - 128 — Windows
        - 64 — Linux
      - لاظهار كيف اتخذت القرار — ممتاز لاكتشاف سبب اغلاق البورت
    - اذا كان امر ping ممنوع في الشبكة — -Pn
    - فحص قائمة — Nmap -iL list
  - البروتوكولات
    - Smb
      - Try unauthorized access — //10.xx
      - Try Unauthenticated access — Smbclient -U '' - N
    - Ftp — Try unauthorized access — Default credentials
      - ftp:ftp
      - anonymous:anonymous
    - Nfs — Similar to smb but for Linux — showmount -e
    - RPC
      - Rpcclient — rpcclient -U "" IP
      - enum4linux
- فحص التطبيق الجوال — Static analysis
  - Mobsf — مراجعة التقرير شرط
  - Android — Jadx-gui
    - Androidmanifest.xml — النظر للصلاحيات
      - هل توجد صلاحيات غير محتاجة ؟
      - انواع الصلاحيات
        - صلاحيات اندرويد — android.xxx
        - صلاحيات خاصة بالتطبيق (Custom)
    - strings.xml
    - كلمات حساسة مكتوبة
      - Usernames
      - Passwords
      - API Keys
      - Private IPs
    - شهادة التطبيق
      - debbug certificate?
      - self signed?
      - Expired?
  - IOS — info.plist
- فحص الشبكة المحيطة
  - متفاعل
    - Ping sweep
      - Fping
      - Nmap
    - Netdiscover
    - ARP scanning — ارسال ARP request — ادق من ping واخفى (فقط في نفس الVLAN)
  - خفي — استلام برودكاست
    - استلام Arp requests
    - لاستلام هاشات — Responder / inveigh — Only crack, cannot be used in pass the hash
- فحص خارجي — Shodan
- تحديد نوع المزود (Mother board) — Mac address (first 3 byte is vendor specific) OUI — Mac address lookup — https://dnschecker.org/mac-lookup.php

استعلام عن الثغرات

- بحث عن ثغرة لتقنية / نسخة
  - مراجع CVE
    - AI — NIST NVD MCP
    - NIST
    - Cvewatch
    - Snyk
    - Github
  - POC
    - Github — 3a7/Cve-watch
      - nomi-sec/PoC-in-GitHub
      - trickest/cve
      - projectdiscovery/nuclei-templates
      - rapid7/metasploit-framework
      - CVEProject/cvelistV5
    - Exploitdb — searchsploit
- ادوات فحص ثغرات
  - Nuclie — فحص التيمبلت الديفولت لكن كن حذر لو كان الموقع صغير ممكن يطيح
  - Vulnerability Management
    - Tenable
    - Qulas
  - CMS — Wpscan
  - Metasploit
  - odoo — Odoomap — https://github.com/MohamedKarrab/odoomap
- مراجع
  - https://hackviser.com/tactics/pentesting
  - https://ippsec.rocks/?#
  - https://hacktricks.wiki/en/index.html

أدوات مهمة

- Web
  - Vulnerability scanner
    - Nikto
    - Nuclie
    - OWASP ZAP — Automated Active Scan
  - Certificate Scanning
    - Sslscan — Check for weak ciphecsuite/protocol
    - testssl
  - Web Proxy
    - Burpsuite
      - Extensions
        - Active Scan ++ — تحسين قوة الفحص
        - Retire.js — لاكتشاف ثغرات المكتبات بشكل افضل
        - JWT Editor — لتعديل الجوت بشكل مباشر
        - Turbo intruder — Race Condition testing
        - 403 Bypasser
      - Collaborator
        - SSRF
        - Out of bound — Blind Command Injection — by using base32
    - ZAP
    - Caido
  - Web Technology
    - wappalyzer browser extension
    - whatweb
  - Discovery tools
    - Files Fuzzing — ffuf
      - -ac — autofilter
      - -r — follow redirect
      - -recursion — --recursion-depth
      - -e — add extension
      - Filters
        - -fs — response size
        - -fw — words counts
        - -fc — status code
        - -fr — regex
    - Subdomains
      - subfinder
      - crt.name
      - dnsdumpster
  - Injection Tools
    - SQLI — sqlmap
      - للحصول على نتيجة ناجحة
        - تعبئة تلقائية للاسئلة — --batch
        - لتغيير اسم المتصفح — --random-agent
        - استعمال ملف — -r
        - تخطي الواف — --skip-waf
        - اختيار الاسلوب — --technique
          - B Boolean-based blind Blind
          - E Error-based Visible output
          - U UNION query Visible output
          - S Stacked queries Executes multiple queries (;)
          - T Time-based blind Blind
          - Q Inline queries DB-specific inline
        - تعديل للتخطي — --tamper
          - between
          - random-case
        - شمل — --chuncked
        - تحديد المعطى — -p
      - بعد الحصول على النتيجة
        - استعلام اكثر
          - --dbs — معرفة قواعد البيانات
          - --tables — لعرض جميع الجداول
          - -T — لعرض جدول بعينه
          - --columns — لعرض جميع صفوف جدول
          - -C — لعرض صف
          - --dump-all — لجلب كل شيء
        - RCE
          - انشاء ملف على الويبروت
          - --os-shell
        - مسح الكاش
          - --purge
          - --flush-session
      - --level (1-5, default 1)
      - --risk (1-3, default 1)
    - XSS
      - xsstrike
      - xsser
    - SSTI — SSTImap
    - XXE (XML Input) — XXEInjector
  - Brute force
    - Hydra
    - Medusa
    - Burpsuite intruder
  - API
    - Scanning
      - wapifuzzer
      - Kiterunner
      - swagger_scanner
    - API qouta Cost — google map — Gmapsapiscanner
  - Exchange — Mailsniper
- Mobile
  - Virtual Machines
    - Seppuku
    - Mobexler
  - Static Analysis — Jadx-gui
  - Reverse Engineering — Frida
    - Ssl pinning bypass script
    - Root prevention bypass
  - Drozer Agent — رؤية سطح الهجوم attack surface
  - Android studio
    - Rooted emulator
    - Emulator with store — لجلب التطبيقات من المتجر
  - adb
    - لتفعيل رووت — adb root
    - لبدء جلسة تحكم للجوال — adb shell
      - استعلام عن التطبيقات
        - package list
        - استعلام عن تطبيقات الطرف الثالث — package list -3
      - مسار التطبيقات — cd /data/data
    - لعرض الاجهزة الجوال المتصلة بالجلسة — adb devices
    - لشبك نظام اخر (كالي) — adb connect ip:port+1 — فتح البورت +1 شرط لسماح الاتصال من ويندوز — netsh
    - رفع ملفات الى الجوال
      - adb install pckg.apk
      - adb push filename filedestination
    - تنزيل تطبيق من الجوال الى النظام الحالي(ويندوز) — adb pull filepath
    - تعديل وكيل الشبكة (البروكسي)
      - اضافة
      - ازالة
  - Mobsf — Automated static alanysis
- Network
  - ادوات اساسية
    - لمعرفة المعلومات الحالية عن الشبكة / الجهاز الحالي
      - ipconfig /all
      - ip a
    - Ping
      - عدم استلام رد لايعني ان الطرف الآخر طافي قد يكون بروتوكول ICMP ممنوع
      - في حال استلام رد TTL
        - 128 — Windows
        - 64 — Linux
    - لمعرفة القفزات للهدف — Traceroute — tracert
    - Nslookup
      - لمعرفة ال ip
      - لمعرفة هل هو عام خارجي او داخلي بناء على ال ip
    - لمعرفة الطريق للهدف — Ip route — ممتازة لحل مشكلة شبكة ال VM
    - Port forwarding
      - netsh — ممتازة لربط انظمة VM في شبكة NAT
      - SSH -L
  - الهجمات على الشبكة
    - Active Directory
      - ADrecon
      - Powerview
      - Powersploit
      - mimikatz
      - rubeus
      - crackmapexec / nxc
      - Subtopic 7
    - فحص الشبكة
      - Bloodhound (AD) — لجلب ملفاته
        - Bloodhound python
        - Rust hound
        - Sharphound
      - Network hound
    - LAN attacks
      - Ettercap
      - Bettercap
      - arpspoof
    - Wireless
      - Rouge access point
      - Evil twin

الأهداف في الهجمات

- Network
  - Active directory
    - Domain controller
      - حصول على shell — https://github.com/CobblePot59/ad-cve-privesc
        - PrintNightmare
        - noPac
        - zerologon
      - استخراج التشويهات — DCsynk — secretsdump.py
    - Exchange server
      - هجمات — Proxyshell
      - نقطة نهاية ضعيفة — /autodiscover.xml — Password spray
      - Guideline — https://github.com/kh4sh3i/exchange-penetration-testing
    - اذا كنت خارج النطاق — جمع اسماء المستخدمين
      - Ldap anonymous access
      - rpcclinet
      - enum4linux
    - هجمات الشهادات — Certighost
  - LAN
    - Routers
      - ARP Spoofing on Gateway — MITM
      - Join Dynamic Routing protocol as a Router
        - OSPF
        - BGP
    - Switches
      - VLAN
        - Hopping attack (Double tagging with Native VLAN)
        - Switch spoof (DTP protocol)
      - STP — Join the STP protocol as switch
    - Servers
      - DNS Spoofing to be gateway — MITM
      - DHCP starving — استهلاك كل العناوين لتفريغ المساحة للهجوم التالي — DHCP Spoofing
    - IoT — Default credentials
  - Wireless
    - Deauthentication attack
    - فحص بروتوكول التشفير المستعمل — WPA WEP WPA2
    - فحص اسلوب المصادقة — Personal? Or enterprise
- Web
  - Login pages
    - ان كانت صفحة خدمة معروفة — Default credentials
    - Bypass login
      - Force browsing — للصفحات خلف المسار المقيد
      - SQLI auth bypass
    - Brute force
      - تاكد هل يوجد rate limit
      - الاسماء
        - username-anarchy
        - انشاء قائمة بناء على اشهر الاسماء بناء على جنسية الهدف — مصادر رسمية باشهر الاسماء
        - اذا لم يكن عندك اي اسم user
          - admin
          - administrator
      - كلمات المرور
        - Seclist — Worst 500
        - cupp
        - النمط المتكرر عند البيئة المستهدفة — recordfuture
      - OTP bypass
        - 4 digit — 10,000 attempt
        - 6 digit — 1,000,000 attempt
    - Forget password
      - Users enumeration — دليل وجود مستخدم
        - رسالة خطأ تثبت وجود اسم المستخدم
        - وقت الاستجابة للرسالة قد يكون دليل على وجود مستخدم
      - Account takeover
        - استغلال اسئلة استرجاع ضعيفة — brute force
        - استغلال tokens
    - CAPTCHA
      - ان كانت ارقام واضحة — OCR read by VLM
      - لا تغيير للتوكن في كل عملية — Brute force on same request
    - Active directory authentication
      - LDAP injection
      - Pasword spray
    - تأكد ان كانت صفحة المسؤول admin مفتوحة في الانترنت
  - Profile
    - File upload
      - معرفة نوع الملف المقبول
        - SVG
          - XXE (also test for any input accept XML)
            - LFI
            - RCE (PHP)
          - XXS
        - GIF
        - JPG
      - تخطي الحماية
        - MIME (Magic bytes) — https://en.wikipedia.org/wiki/List_of_file_signatures
        - Content type — Fuzzable
        - Double extension
      - Webshell
        - لاختيار الويب شيل الانسب يجب معرفة الامتداد المستعمل
        - اذا عكس محتوى الملف دون تنفيذ execution — جرب امتداد آخر
        - Apache — ارفع ملف جديد باسم .htaccess — AddType application/x-httpd-php .cth — الان امتداد cth ينفذ php
    - CSRF
      - تغيير ايميل
      - تغيير كلمة مرور
  - Services — ثغرات حرجة على خدمات متكررة
    - Tomcat — Metasploit module — tomcat_jsp_upload_bypass
    - Oracle erp — CVE-2022-21587
    - SharePoint — CVE-205-53770
  - HTTP verbs (Methods)
    - جرب
      - PUT
      - PATCH
      - DELETE — خطيرة
    - 405 Unsupported Method — جرب مختلف الميثود
      - GET
      - POST
      - HEAD
    - جربها كلها من wordlist
  - CORS misconfigurations — اذا جاء الشرطين
    - Allow origin *
    - Credentials trrue
  - X-Frame-options — اذا لم يوجد اي تقييد — Clickjacking
  - Restricted page
    - 403 forbidden
      - 403 jump/403 bypasser extension in burp
      - اضف — X-Forward-For: 127.0.0.1
    - 401 unauthorized — Try diffrent HTTP METHOD
    - جرب الوصول لملفات وراءها — Force browsing — ffuf --recursion
  - API
    - /api/v1/version — غالبا اول هدف للتاكد بوجودها
    - Users
    - Id — BOLA/IDOR — ان كان رقم عشوائي — قد تكون بهاش ضعيف
  - Parameters
    - البحث عنها
      - Crawling
      - Parameter fuzzing
        - GET — ffuf -u https://target.com/?FUZZ
        - POST — ffuf -u https://target.com/ -X POST - d 'FUZZ=test'
    - ان وجد
      - language (en) — LFI
      - File (page.php) — LFI
      - Url (host.com)
        - LFI
        - SSRF
          - Port scan
          - RFI
      - اشياء حساسة ينبغي ان لاترسل — Token sent via url
      - Reflected query
        - Number — رقم كبير جدا (قد يؤدي الى error) — 999999999999999
        - جرب
          - SSTI
          - XSS
        - بيانات تبدو مسترجعة من قواعد البيانات — UNION SQLI
      - لها علاقة باسترجاع بيانات من قواعد البيانات — SQLI
      - هجمات الحقن الأخرى
  - Input field
    - حروف يجب تجربتها
      - ' — هل يخرج رد مختلف او error
      - ;
      - <
      - HTML injection
    - Reflected
      - XSS
      - SSTI
      - بيانات مسترجعة من قواعد البيانات — UNION SQLI
    - Unreflected — بيانات ترسل للقواعد البيانات لكن لايعكس شيء — Time based SQLI
    - Comment
      - Stored XSS
      - Prompt injection for LLMs (jf exist)
    - Execute System command on the server — Command Injection
    - other attacks consider testing
      - try SSI paylod
      - XSLT
  - File upload
    - لمعرفة مسار الملف
      - Browser DevTools
      - Fuzzing — /uploads
      - HTTP/API Response — ظهور المسار في الرد
    - اذا عرفت مسار الملف — ارفع webshell
    - ان كان pdf فقط — XSS Via pdf
  - Race Condition (on Limited Functions)
    - انواع المحدودية
      - اخذ وقت محدد
      - كمية (مثل المال)
      - عملية ذات استعمال واحد
    - أمثلة
      - activation token for 1 use case — تفعيل حسابين بتوكن واحدة (وهي استعمال واحد)
      - transfer money — ارسال نفس الرسالة قد يضاعف القيمة
      - add money/credit
      - Update email and Login
- Mobile
  - داخل shell على النظام عن طريق adb
    - Share_preference — هب يتم مشاركة بيانات حساسة
    - مراجعة Logs — Logcat
      - خذ رقم العملية PID للتطبيق — adb shell ps -A | grep com.example.app
      - اقرأ سجلات التطبيق فقط — adb shel ps | grep PID
    - Tmp file — ابحث هل تم حفظ ملف مؤقت وفيه بيانات حساسة
    - database — sqlite3
  - في الكود المرجعي يوجد Exported
    - Activists — Login bypass
    - Services — Intent manipulation
    - Broadcast receivers — Privileged actions
    - Content provider — Data exposure
  - داخل التطبيق Input field
    - SQLI
    - XSS
- Database
  - Dump tables
  - هل يمكن تنفيذ اوامر على النظام
    - اذا نعم قم بتفعيل shell — Execute base64 to get a shell (remove spaces =)
    - LFI
  - اخذ التشويه — responder

Presented with xmind